

ISO 27001与等保2.0控制差距评估及整改规划

CYB-T8-014 | L4 强长程 | v1.0.0

候选 Golden Output

基于固定提交的公开开源证据与显式场景包装。不得视为十年以上经验专家已审核结论。

业务背景

客户以DefectDojo公开Prowler样例作为云控制证据集，要求对ISO/IEC 27001:2022和GB/T 22239-2019相关控制做桌面预评估；任务不构成认证或等保测评结论。

核心决策

不能宣称全面符合：长期未使用凭证和密码历史策略形成明确差距；root账户条目的FAIL与扩展文本矛盾，必须判为证据不足；未使用安全组是Not Scored信息项，不能冒充基准不符合。

数据冻结日：2026-07-27 | 来源：公开仓库固定提交 | 安全边界：仅本地离线分析

1. 管理层摘要

不能宣称全面符合：长期未使用凭证和密码历史策略形成明确差距；root账户条目的FAIL与扩展文本矛盾，必须判为证据不足；未使用安全组是Not Scored信息项，不能冒充基准不符合。

训练评估人员识别扫描状态与证据文本冲突、区分Scored与Not Scored，并在标准正文受版权保护时使用合法摘要和官方登记信息。

最高优先事项

ID	核心发现	等级/状态	管理动作
CMP-001	example_user访问密钥创建后未使用且超过90天未轮换，支持身份生命周期和访问权回收差距	不符合/高	P0 核实example_user依赖后停用闲置凭证并建立90天自动复核
CMP-002	账号密码策略的历史记忆低于24，样例明确给出FAIL和整改要求	不符合/中	P1 评估服务账号影响后将密码历史提升至目标并保留变更证据
CMP-003	CHECK_RESULT为FAIL，但扩展文本写明root在最近1天未被访问，证据自身矛盾	证据不足/待复核	P1 复核TITLE_ID 1.1解析逻辑并补采root credential report/CloudTrail

结论均需结合证据定位阅读；风险路径或相关性不等同于已发生因果。

2. 范围、方法与安全边界

方法采用文件盘点、字段校验、时间/资产/身份关联、证据三角验证、风险语境化、整改与回滚设计、复核门禁八个阶段。评级显式纳入业务约束。成熟安全专家预计耗时为任务元数据所列分钟数；完成任务通常需要100个以上必要原子操作。

输入材料

文件	用途
00_数据来源与脱敏说明.json	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
01_评估范围与法律边界.md	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
02_Prowler公开样例.csv	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
03_Prowler公开样例.json	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
04_Prowler_ASFF公开样例.json	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
05_标准官方登记与版本.json	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
06_合法控制摘要与映射.csv	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
07_业务与整改约束.md	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
08_五态判定规则.md	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。
09_证据索引.csv	用于证据关联、范围确认或专业判断；详见文件内容和证据定位。

硬边界：禁止访问公网或未授权系统；IP仅使用RFC1918/RFC5737，域名仅使用.test；任何验证仅限输入材料和本地隔离环境。

3. 事实与证据链

下表区分事实、专业判断与仍需验证事项。证据ID可回到输入文件定位。

发现ID	对象/阶段	事实或结论	风险/状态	证据定位
CMP-001	闲置凭证	example_user访问密钥创建后未使用且超过90天未轮换，支持身份生命周期和访问权回收差距	不符合/高	CMP-E02,ISO-A.5.16,ISO-A.5.18
CMP-002	密码历史	账号密码策略的历史记忆低于24，样例明确给出FAIL和整改要求	不符合/中	CMP-E03,ISO-A.5.17
CMP-003	root账户使用	CHECK_RESULT为FAIL，但扩展文本写明root在最近1天未被访问，证据自身矛盾	证据不足/待复核	CMP-E01
CMP-004	未使用安全组	条目标记Not Scored、Extra和Informational，不属于该CIS基准评分项	改进项/不计入基准缺口	CMP-E04
CMP-005	媒体运输	本次范围为云IAM证据且明确不涉及媒体运输，只能对本次评估记录不适用	不适用/有范围理由	01 scope,07 constraint

证据强度规则：日志/配置快照证明观测事实；扫描结果是线索；缺少运行证据时必须降级表达。

4. 风险与业务影响

评级同时考虑严重度、可利用性/权限可达性、暴露面、资产价值、业务连续性和证据置信度，不以单一分数机械排序，也不得把技术严重度直接等同于业务优先级。

状态	使用规则	本次示例
已符合	设计与运行证据均充分	本次证据子集无独立样例
部分符合	控制存在但覆盖或运行不完整	需要补充运行证据
不符合	可靠证据明确显示要求未满足	CMP-001/CMP-002
不适用	有范围理由且不转移风险	CMP-005
证据不足	来源冲突或证据不能支持结论	CMP-003

CMP-001 | 不符合/高

example_user访问密钥创建后未使用且超过90天未轮换，支持身份生命周期和访问权回收差距。业务影响结合闲置凭证的重要性评估；证据：CMP-E02,ISO-A.5.16,ISO-A.5.18。

CMP-002 | 不符合/中

账号密码策略的历史记忆低于24，样例明确给出FAIL和整改要求。业务影响结合密码历史的重要性评估；证据：CMP-E03,ISO-A.5.17。

CMP-003 | 证据不足/待复核

CHECK_RESULT为FAIL，但扩展文本写明root在最近1天未被访问，证据自身矛盾。业务影响结合root账户使用的重要性评估；证据：CMP-E01。

CMP-004 | 改进项/不计入基准缺口

条目标记Not Scored、Extra和Informational，不属于该CIS基准评分项。业务影响结合未使用安全组的重要性评估；证据：CMP-E04。

CMP-005 | 不适用/有范围理由

本次范围为云IAM证据且明确不涉及媒体运输，只能对本次评估记录不适用。业务影响结合媒体运输的重要性评估；证据：01 scope,07 constraint。

5. 优先级与处置方案

所有行动绑定优先级、责任主体、完成时限、验证方式和回滚方案。

优先级	责任主体	行动	完成时限	验证	回滚
P0	IAM平台主管	核实example_user依赖后停用闲置凭证并建立90天自动复核	5个工作日	凭证报告与调用日志均无依赖，停用后无业务错误	恢复凭证仅需双人审批并设置短期到期
P1	身份治理组	评估服务账号影响后将密码历史提升至目标并保留变更证据	10个工作日	策略读取、测试账号轮换和回退演练	恢复上一策略并保持补偿监控
P1	审计与云安全组	复核TITLE_ID 1.1解析逻辑并补采root credential report/CloudTrail	5个工作日	原始证据与解析状态一致	保留证据不足状态，不以扫描FAIL替代结论
P2	云平台主管	清理未使用安全组但不计入基准不符合关闭率	30天	资源关联查询为空且删除后无影响	按IaC恢复安全组

责任人变更、时间延后或风险接受必须形成审批记录，不得用口头承诺替代关闭证据。

6. 验证、回滚与恢复门禁

验证顺序：先保存变更前快照，再实施单一控制，执行功能与安全用例，观察业务指标，最后由业务Owner与安全Owner共同签字。

门禁	通过条件	失败处置
证据门禁	原始证据可定位、时间一致、采集来源明确	停止定性并补采证据
安全门禁	关键ID对应的控制测试通过且无gating风险	按表中回滚方案恢复
业务门禁	错误率、登录失败率、延迟或RTO不超过约束	触发回滚并进入变更复盘
恢复门禁	监控覆盖、责任人签字、残余风险获批准	保持隔离/缓解状态

禁止为了快速恢复而删除日志、取消审计或绕过双人审批；回滚必须恢复业务但不得重新开放已确认高风险路径。

7. 分阶段路线图

阶段	时间	目标	输出/复核
阶段一 / P0	0-24小时	隔离高风险暴露或断开高杠杆控制关系	应急变更单、证据快照、冒烟验证
阶段二 / P1	2-14天	完成结构性修复、最小权限与验证自动化	回归用例、权限模拟、Owner签字
阶段三 / P2	30-90天	制度化持续监控、指标和季度复核	趋势指标、抽样记录、演练报告

阶段退出条件是证据完成而非日历到期；未满足验证门禁的项目保持开放。

8. 限制、不确定性与后续复核

证据边界与不确定性：Prowler样例中root条目的结果和扩展说明冲突，只能判为证据不足；本任务使用自编短摘要，不替代ISO标准正版或GB/T 22239-2019完整正文和正式测评。

本报告局限：仅基于随包冻结的公开证据和明确标注的场景包装，未连接任何外部系统。上游测试夹具不代表现实企业生产状态；没有证据时不补写事实，不把扫描、关系或实验叙事自动扩大为现实因果。

待复核清单

项目	责任主体	复核方法
关键事实与风险评级	10年以上经验网安专家	逐条回到输入证据并复算
整改可行性与业务影响	系统Owner/变更经理	在维护窗口执行演练
合规/ATT&CK/零信任映射	对应领域专家	核对冻结版本与适用范围
最终状态	独立复核人	按Rubric item-level复核

9. 证据索引

输入文件与关键标识如下。文件名与instruction.json、metadata.json保持一致。

序号	输入文件	证据用途
1	00_数据来源与脱敏说明.json	范围/资产/日志/配置/约束/复核证据
2	01_评估范围与法律边界.md	范围/资产/日志/配置/约束/复核证据
3	02_Prowler公开样例.csv	范围/资产/日志/配置/约束/复核证据
4	03_Prowler公开样例.json	范围/资产/日志/配置/约束/复核证据
5	04_Prowler_ASFF公开样例.json	范围/资产/日志/配置/约束/复核证据
6	05_标准官方登记与版本.json	范围/资产/日志/配置/约束/复核证据
7	06_合法控制摘要与映射.csv	范围/资产/日志/配置/约束/复核证据
8	07_业务与整改约束.md	范围/资产/日志/配置/约束/复核证据
9	08_五态判定规则.md	范围/资产/日志/配置/约束/复核证据
10	09_证据索引.csv	范围/资产/日志/配置/约束/复核证据

关键标识：CMP-001、CMP-002、CMP-003、CMP-004、CMP-005、TITLE_ID=1.1、Not Scored、ISO-A.5.18、GB-T-8.1.4.2

文档状态：候选Golden，待网安专家审核；不得声称已由十年以上经验专家生产或签字。